WEB APPLICATION SECURITY AUDIT & BIA REPORT

Target: https://owasp.github.io/juice-shop/

Automated Defensive Posture Assessment | Date: 2026-09-18 22:39:24

Target Infrastructure Profile

Target URL:
https://owasp.github.io/juice-shop/

IP Address: 185.199.110.153

Web Server: GitHub.com

Duration: 1.67 seconds

Defensive Posture Score

75.0 **[C]**

Adequate baseline, but notable configuration weaknesses increase exposure.

1. Executive Summary & Findings Distribution

CRITICAL	HIGH	MEDIUM	LOW	INFO
0	1	2	3	1
CVSS 9.0-10.0	CVSS 7.0-8.9	CVSS 4.0-6.9	CVSS 0.1-3.9	CVSS 0.0

The security posture assessment for 'https://owasp.github.io/juice-shop/' yielded an overall score of 75.0/100 (Grade: C). The audit identified 0 Critical, 1 High, 2 Medium, and 3 Low severity findings. Immediate remediation is recommended. The presence of high-severity vulnerabilities exposes the organization to elevated regulatory risk under frameworks like PCI-DSS and GDPR, as well as potential session hijacking, data leakage, or infrastructure compromise.

2. Business Impact Analysis (BIA) & Regulatory Compliance

Impact Vector	Evaluated Risk	Business Consequence & Scope
Confidentiality (CIA)	High	Risk of unauthorized data interception, session cookie hijacking, or internal server metadata leakage.
Integrity (CIA)	High	Exposure to clickjacking, malicious script execution (XSS), or unauthorized cross-origin tampering (CORS).
Availability (CIA)	Low	Susceptibility to denial-of-service, resource exhaustion, or operational downtime from unpatched software.
Financial Exposure	Elevated	Elevated - Vulnerable to targeted attacks and regulatory scrutiny
Brand & Reputation	High	High - Potential customer churn and security advisory disclosures

Regulatory Framework	Compliance Status & Applicable Standard
PCI-DSS 4.0	NON-COMPLIANT (Req 4.1: Strong Cryptography & Req 6.4: Web Security)
HIPAA Security Rule	AT-RISK (Section 164.312(e)(1) Transmission Security & ePHI Protection)
GDPR Art. 32	COMPLIANT (Demonstrates reasonable technical hygiene)

3. Transport Layer & Defensive Controls Audit Details

A. Transport Layer Security (TLS/SSL Architecture & Certificate Audit):

Negotiated Protocol	TLSv1.3 (Preferred Cipher: TLS_AES_128_GCM_SHA256)
Certificate Status	VALID & ACTIVE (43 days remaining)
Validity Window	2026-08-02 23:38:02 UTC to 2026-10-31 23:38:01 UTC
Cryptographic Keys	RSA 2048 bits (Signature Digest: SHA256)
Subject Identity	CN=*.github.io
Certificate Issuer	CN=YR1,O=Let's Encrypt,C=US
Alternative Domains	*.github.com, *.github.io, *.githubusercontent.com, github.com, github.io, githubusercontent.com

B. HTTP Defensive Headers Audit Summary:

Active Defensive Headers	None identified
Missing Defensive Headers	Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy

C. Cookie Security & Session Hygiene:

Cookie Directives	No Set-Cookie directives were issued on the audited page.

4. Detailed Security Findings & Remediation Guide

[HIGH] HDR-HSTS-MISSING: Missing HTTP Strict-Transport-Security (HSTS) Header | CVSS: 7.4

Category: HTTP Defensive Headers (PCI-DSS 4.0: Req 6.4 | OWASP A05:2021 | NIST SP 800-52r2)
Description: The server does not enforce HTTPS via the Strict-Transport-Security header.
Impact: Vulnerable to SSL-stripping and man-in-the-middle downgrade attacks on insecure Wi-Fi/networks.
Evidence: *Header 'Strict-Transport-Security' is absent.*
Remediation: Add 'Strict-Transport-Security: max-age=31536000; includeSubDomains; preload' to all HTTPS responses.

[MEDIUM] HDR-CSP-MISSING: Missing Content-Security-Policy (CSP) Header | CVSS: 6.1

Category: HTTP Defensive Headers (OWASP A03:2021 | PCI-DSS 4.0: Req 6.4)
Description: No Content-Security-Policy header was returned by the server.
Impact: Lack of CSP drastically increases vulnerability to Cross-Site Scripting (XSS), malicious script injection, and clickjacking.
Evidence: *Header 'Content-Security-Policy' is absent.*
Remediation: Define and deploy a strict CSP restricting script, object, and style sources (e.g. default-src 'self').

[MEDIUM] HDR-XFO-MISSING: Missing X-Frame-Options / Clickjacking Protection | CVSS: 5.4

Category: HTTP Defensive Headers (OWASP A05:2021 | WASC-15)
Description: The application does not provide clickjacking protection via X-Frame-Options or CSP 'frame-ancestors'.
Impact: Attackers can embed the target page in a hidden iframe on a malicious site to trick users into unintended actions.
Evidence: *Neither 'X-Frame-Options' nor 'frame-ancestors' present.*
Remediation: Configure 'X-Frame-Options: DENY' or 'SAMEORIGIN', or use CSP 'frame-ancestors 'self''.

[LOW] HDR-XCTO-MISSING: Missing X-Content-Type-Options Header | CVSS: 3.7

Category: HTTP Defensive Headers (OWASP A05:2021)
Description: The 'X-Content-Type-Options: nosniff' header is missing from server responses.
Impact: Older or legacy browsers may sniff the response MIME type, potentially executing uploaded text or images as HTML/JavaScript.
Evidence: *Header 'X-Content-Type-Options' is absent.*
Remediation: Add 'X-Content-Type-Options: nosniff' to all HTTP responses.

[LOW] HDR-RP-MISSING: Missing Referrer-Policy Header | CVSS: 3.1

Category: HTTP Defensive Headers (OWASP A05:2021)
Description: The server does not specify a Referrer-Policy.
Impact: Sensitive URLs with session tokens, user IDs, or internal query parameters may leak in the Referer header to external third parties.
Evidence: *Header 'Referrer-Policy' is absent.*
Remediation: Configure 'Referrer-Policy: strict-origin-when-cross-origin' or 'no-referrer'.

[LOW] HDR-PP-MISSING: Missing Permissions-Policy Header | CVSS: 2.5

Category: HTTP Defensive Headers (Modern Defensive Standards)
Description: The server does not restrict browser device capabilities using Permissions-Policy.
Impact: Enables embedded third-party scripts or iframes to request sensitive browser APIs (camera, geolocation, microphone).
Evidence: *Header 'Permissions-Policy' is absent.*
Remediation: Configure 'Permissions-Policy: camera=(), microphone=(), geolocation=()'.

[INFO] LEAK-SERVER: Web Server Version Banner Disclosure | CVSS: 0.0

Category: Tech Stack & Vulnerability Exposure (OWASP A05:2021)
Description: The server exposes internal technology metadata via 'server: GitHub.com'.
Impact: Facilitates targeted attacker reconnaissance and CVE matching.
Evidence: *server: GitHub.com*
Remediation: Mask or suppress the 'server' response header in your web server/application configuration.

5. Strategic Remediation Roadmap & Operational Next Steps

Remediation Milestone	Action Plan & Operational Scope
Phase 1 (Immediate: 24-48 hrs)	Resolve all CRITICAL and HIGH severity findings. Deploy missing HSTS headers, renew expiring SSL certificates, and restrict any exposed repository or config files.
Phase 2 (Short-Term: 1-2 weeks)	Implement a hardened Content-Security-Policy (CSP) to mitigate Cross-Site Scripting (XSS). Ensure all session cookies mandate HttpOnly and SameSite=Lax/Strict.
Phase 3 (Operational Hygiene)	Suppress server technology banners (Server, X-Powered-By). Deploy RFC 9116 security.txt to facilitate ethical vulnerability disclosures, and integrate automated scans into CI/CD pipelines.